

Analyser un outil de protection numérique

Exercice 2 – Gérer les accès et les privilèges

Contexte : L'association de M. Rens prête 10 postes informatiques à ses participants pour la création de CV et de lettres de motivation. Le but est de sécuriser ces machines.

Question 1 – Bonnes pratiques d'authentification et d'accréditation

- Le constat actuel est critique : les utilisateurs emploient leur identifiant comme mot de passe (par exemple, le login "participant-3" a pour mot de passe "participant-3").
- Cette faille majeure doit être résolue au plus vite.
- Il faut imposer une politique de mots de passe stricts : ils doivent être différents du login et contenir une combinaison de majuscules, chiffres et caractères spéciaux.
- Il est fortement préconisé d'obliger le changement du mot de passe à la première ouverture de session.
- Le compte doit se verrouiller temporairement après plusieurs erreurs de saisie, et le prêt d'identifiants entre utilisateurs doit être formellement interdit.
- En matière d'accès, le principe du moindre privilège s'impose : un utilisateur ne doit pouvoir ouvrir que ses propres documents et les fichiers distribués par le formateur.

Question 2 - Précautions concernant le compte administrateur

- M. Rens ne doit pas se servir de son compte administrateur pour naviguer ou travailler au quotidien.
- Il est recommandé de lui créer un compte standard pour ses tâches courantes.
- Le compte à hauts privilèges est à réserver aux actes de maintenance.
- Ce compte sensible exige un mot de passe très robuste qui ne doit jamais être partagé.
- De manière générale, il faut limiter autant que possible le nombre d'administrateurs sur le réseau.

Question 3 – Quels privilèges accorder à chaque utilisateur ?

- L'ouverture totale du dossier partagé est une vulnérabilité, car n'importe qui peut effacer ou altérer le travail d'un autre participant.
- Pour y remédier, chaque participant aura besoin d'un répertoire personnel où il sera le seul à posséder les droits de lecture et d'écriture.
- Un répertoire commun de "Ressources" sera créé : le formateur aura un contrôle total dessus, tandis que les participants n'y auront accès qu'en lecture seule.
- Bien entendu, les administrateurs gardent des droits complets sur l'ensemble de l'arborescence pour assurer la maintenance.

Question 4 – Obligations liées au stockage de données personnelles

- Étant donné que l'association héberge des CV, des coordonnées et des noms, elle est pleinement soumise à la réglementation du RGPD.
- Elle a l'obligation de cartographier ces données : savoir ce qui est récolté, dans quel but, et pour combien de temps.
- La tenue d'un registre de traitement est indispensable, tout comme le déploiement de protections (mots de passe forts, sauvegardes fiables, limitation des accès).
- L'organisme doit être en mesure de démontrer sa conformité au RGPD à tout instant.
- S'il y a une fuite d'informations, une déclaration doit être faite sous 72 heures.

Exercice 3 - Sécuriser les communications

Contexte : Actuellement, les PC dédiés aux participants partagent le même réseau que les pôles sensibles (comptabilité, direction). C'est un risque majeur d'accès non autorisé à des données confidentielles.

Question 1 – Solution

- L'approche la plus pertinente consiste à déployer des VLANs.
- Cette méthode permet de cloisonner virtuellement les différents pôles sur une même infrastructure physique.
- Grâce à cela, chaque service devient totalement imperméable aux autres.

Question 2 – Mise en place

- Le déploiement des VLANs exige plusieurs manipulations.

- Il faut commencer par se connecter à l'interface du switch pour déclarer les VLANs dédiés à chaque service.
- On affecte ensuite chaque port physique du switch au VLAN qui lui correspond.
- La connexion entre le switch et la box internet doit être basculée en mode "trunk" pour autoriser le passage de l'ensemble des VLANs.
- L'opération se termine par une phase de test pour valider l'étanchéité des réseaux internes et la bonne connectivité à Internet.

Question 3 – Simulation

- L'architecture a été maquettée sur le logiciel Packet Tracer.
- Suite à la déclaration des VLANs et à l'affectation des ports , les vérifications confirment le bon fonctionnement : les participants ne voient plus le réseau de la direction, mais accèdent toujours au web.
- Le cloisonnement réseau est donc un succès.

Question 4 - Limites de la box

- Pour que l'infrastructure VLAN fonctionne parfaitement, le routeur (ou la box) doit être capable de gérer de multiples sous-réseaux.
- Cela requiert la création de sous-interfaces virtuelles possédant leurs propres adresses IP.
- Le problème est que les box internet classiques fournies par les opérateurs n'offrent pas ce type de paramétrage avancé.
- Dans un environnement de production, il faudra probablement acheter un routeur professionnel pour faire fonctionner cette architecture.

Conclusion

En définitive, ce compte-rendu prouve qu'il est possible de relever considérablement le niveau de sécurité d'un parc informatique sans moyens démesurés. L'application stricte d'une politique de mots de passe, la restriction des droits d'accès ou encore le cloisonnement des réseaux (VLANs) éliminent la majorité des vulnérabilités de base. De plus, le respect scrupuleux des normes comme le RGPD reste un enjeu incontournable. L'application de ces bonnes pratiques garantit un environnement informatique nettement plus fiable.